

Assurance Assignment: Hand-in

Role: SAMM specialist

Francesco Maria Fuligni | Group 13

Core

Practice – Security Testing (Verification). Dedicated security test cases for known-risk areas, run regularly. **Simplified score: Level 2 before and after the improvement.**

Before my improvement, the repository already had authorization, path-traversal and login-throttling tests. GitHub Actions ran pytest on pull requests to `main` and pushes to `main` and feature branches. Link-access tests returned HTTP 200 with a PDF for an issued link, HTTP 404 without a PDF for four unissued-link patterns, and kept two users' documents separate. These repeatable tests cover known risks; systematic security coverage tracking, needed for Level 3, was missing.

I added a regression for the SHA-1 candidate previously checked manually: `GET /api/get-version/640d87e741e6aa4c669a82a4cd304787960513ab` returns HTTP 404 with no PDF. I also made four unissued-link tests check that responses contain no fixture secrets, recipients or filenames. On 30 September 2026, all seven link-access cases and Ruff passed. The test assertions and results are the evidence; the change is in commit `fbae18a`.

Further Work

Option 1 – Second practice audited: Secure Build (Implementation). The simplified score is Level 1 at baseline and a scoped Level 2 after the improvements. Initially, CI did not build the Docker image and Docker used flexible Python dependency ranges. The image had `cryptography 50.0.2`, while the unused local lockfile specified `50.0.1`.

Option 2 – Second real improvement. I added a CI Docker build and `import rmap` check, plus a tracked `requirements.txt` pinning 26 registry distributions. Docker and pytest install these requirements; CI regenerates the file and checks for drift. The Python base image is pinned by digest. Verification found all 26 versions matched the image, and `pip check` and `import rmap` passed. Commits `8a1073f`, `f0cd7ae` and `f7e50c3` record the work.

The scoped build score covers the server's Python runtime. System packages and the full Compose stack are not covered, RMAP uses a release tag, and the Docker check does not start the full application. No dependency or image vulnerability gate is established, so I do not claim Secure Build Level 3. The link tests use in-memory SQLite and a test-only watermark; they show these specific outcomes, not general link unpredictability.

Hours

Track 2 time spent (self-reported): 9 hours (5 Core + 4 Further Work).